International Journal of Information Security (2026) 25:186
https://doi.org/10.1007/s10207-026-01343-w

REGULAR CONTRIBUTION

Authorization assurance for tool-using LLM agents: a structured review of enforcement semantics and effect-level security evidence

Mohamed Abbas Elmasry[1]

Received: 2 September 2026 / Accepted: 27 September 2026
© The Author(s) 2026

Abstract

Tool-using large language model (LLM) agents exercise authority over protected resources through APIs, tools, credentials, and external services. This structured review asks whether authorization claims are supported at the enforcement and observation boundaries relevant to the claimed effect. A 75-source evidence library was screened into a 30-source analytical corpus (15 strict agent sources, 6 sensitivity sources, and 9 authorization/assurance comparators), yielding 92 Source-Claim Records. Within this closed corpus, five strict sources made mediation or non-bypassability claims with heterogeneous evidence endpoints; all three evaluable least-privilege sources narrowed available authority without measuring trajectory-wide effective privilege; no evaluable revocation claim appeared among 21 agent-focused sources; and no delegation-containment claim appeared in the 30-source corpus. Final-state correctness was also distinct from authorization correctness. We integrate these findings through an Authorization Assurance Claim Model linking claim scope, obligations, enforcement, evidence, protected effect, and residual assumptions. The resulting MAAP is presented as a preliminary, review-derived minimum reporting framework, not a validated scoring or certification instrument. The supplementary workbook provides the screening decisions, complete coding dataset, source-property matrix, sensitivity analyses, and independent coding audit.

Keywords LLM agents · Authorization assurance · Access control · Tool use · Security evaluation · Prompt injection

1 Introduction

Large language models increasingly operate as action-capable components rather than text generators. Tool-using agents can retrieve private data, invoke APIs, change application state, communicate with external parties, maintain persistent memory, and coordinate multi-step actions [1–6]. The security consequence is qualitative: an incorrect output may remain informational, whereas an agent action can exercise authority and create a persistent effect in a protected system.

Authorization is therefore a system property, not only a model-behavior property. The model proposing an action, the component holding credentials, the policy decision point (PDP), the policy enforcement point (PEP), the executor, and the protected resource may be different components. Classical access-control principles identify the principal, resource, operation, policy, enforcement boundary, and relevant context [7–13]. Emerging protocols and operational guidance increasingly acknowledge the same boundaries for agentic systems [14, 15].

Prompt injection, persistent-state manipulation, unsafe tool use, privacy leakage, and compromised control flow can redirect the causal path from model input to external effect [2, 3, 16–25]. Instruction hierarchies, structured interfaces, information-flow control, tool gates, and agent firewalls reduce parts of that risk [26–33], but a mechanism label or benchmark score does not determine the strength of the resulting authorization claim. Hiding a tool may leave equivalent operations available through a shared tool; rejecting a call may leave another path to the resource; a correct final state may conceal a missing confirmation; and central revocation may precede actual downstream denial [34–38].

We call the resulting problem *authorization assurance*: justified confidence that authorization controls mediate the in-scope executable paths capable of producing specified protected-resource effects, under an explicit system boundary, threat model, and set of trusted assumptions. The core question is claim–evidence proportionality—whether the

✉ Mohamed Abbas Elmasry
malmasry@eelu.edu.eg

[1] Department of Management Information Systems, Egyptian E-Learning University (EELU), Cairo, Egypt

Published online: 10 November 2026

enforced semantics and reported observations justify the property at the scope in which it is stated. This adapts established security-assurance reasoning, which links claims, requirements, assumptions, verification conditions, and evidence [39–43], to the execution chain of tool-using agents.

Publication-level categorization alone cannot answer this question. One paper may provide a formal guarantee for an interpreter, an empirical benchmark result for a particular attack, and a broader discussion claim about the system as a whole. Treating the paper as uniformly "secure" or "effect-level" would erase the different boundaries of those claims. The review therefore changes the unit of synthesis from the publication to the individual source claim and preserves the relationship between that claim and the evidence used to support it.

The review addresses four research questions:

RQ1: What authorization-security properties are claimed, and under which principals, system boundaries, threat models, protected resources, and assumptions?

RQ2: Where and when are those properties enforced across delegation, planning, tool admission, execution, and protected-resource interaction?

RQ3: To what extent does reported evidence support the obligations implied by each claimed property?

RQ4: Which recurring claim–enforcement–evidence mismatches limit assurance, and what minimum reporting profile follows from them?

The review makes four evidence-grounded contributions. First, it develops an Authorization Assurance Claim Model that operationalizes established access-control and assurance principles for tool-using LLM agents. Second, it introduces the SCR as a claim-level unit connecting obligations, enforcement, evidence, effect, and residual assumptions. Third, it reports corpus-bounded findings on mediation, effective privilege, revocation, delegation, and benchmark semantics. Fourth, it derives MAAP as a preliminary reporting framework whose elements are traceable to both coded gaps and established security principles.

2 Scope and positioning against prior reviews

The surrounding literature already contains extensive survey activity; novelty cannot rest on claiming that authorization, agent security, or evaluation has not been reviewed. Broad LLM-security and safety surveys organize attacks, privacy risks, robustness failures, and defenses [16–18]. Agent-focused reviews cover threats, architectures, defensive mechanisms, evaluation frameworks, case studies, and real-world deployment concerns [2–5, 19]. Domain and governance reviews extend this picture to autonomous cyber defence, trust/risk/security management, and regulatory anchoring [6, 44, 45]. These sources establish the field but generally retain the publication, threat, mechanism, or lifecycle stage as the principal unit of synthesis.

Related work on human–AI integration in cybersecurity emphasizes the operational setting in which AI-supported decisions and incident workflows are embedded [46]. Focused security surveys in the target journal also demonstrate that a bounded corpus can support a useful synthesis when the interfaces, components, and security properties under review are defined explicitly [47]. Neither precedent, however, replaces claim-level appraisal of agent authorization evidence.

Authorization research provides the semantic foundations used here. Contemporary studies address compound objects and temporal constraints [48], conflict and redundancy in policy models [49], dynamic risk state [50], cryptographic revocation and traceability [51], policy evaluation and mining [52–54], RBAC and information-flow structures [55, 56], and privacy, cloud, IoT, and spatiotemporal authorization [57–59]. Formal and cryptographic mechanisms show how policy can be bound to protocol or resource acceptance [60, 61]. These contributions do not evaluate heterogeneous LLM-agent claims; they supply comparators for interpreting privilege, mediation, delegation, and revocation.

Prompt-injection and tool-security research spans model-output attacks, online adversarial interaction, persistent memory, executable agents, structured interfaces, and realistic web environments [20–25, 62, 63]. More recent mechanisms move selected controls outside unconstrained model reasoning through tool-dependency constraints, capability/provenance tracking, information-flow policy, or independent interception [27, 28, 64, 65]. Recent syntheses, system studies, and design proposals foreground delegated authority, inter-agent communication, security patterns, and system-level control [29–33, 38, 66]. Prompt injection can therefore be a cause of authorization failure, but influence, tool selection, call submission, execution, and attacker-defined resource state remain different observations.

Agent benchmarks make this distinction concrete. AgentDojo [20], ToolEmu [67], ASB [68], AgentHarm [69], τ-bench [36], ToolSandbox [37], and WASP [62] observe progressively richer combinations of calls, trajectories, and environment state. Yet richer state does not automatically encode identity, consent, delegation, revocation, or every process condition that makes a transition authorized. Security-assurance research provides the closest methodological precedent by treating claims, arguments, assumptions, verification, and evidence as traceable but non-interchangeable artifacts [39, 41–43, 70]. Table 1 positions this review at their intersection.

The review is therefore neither a general agent-security taxonomy nor a new access-control architecture. Its distinctive contribution is a claim-level authorization-assurance

Table 1 Positioning against representative prior-review families

Prior-review family	Primary organizing unit	Distinctive role of this review
Broad LLM security and safety [16–18]	Attack, vulnerability, privacy, robustness, defense	Restricts synthesis to authorization claims in action-capable systems
LLM-agent security and architecture [2–5, 19]	Threat, architecture, lifecycle, mechanism, evaluation	Uses the individual authorization claim as the analytical unit
Cyber-defence, TRiSM, and safety reviews [6, 44, 45]	Domain, governance, operational risk	Focuses on technical claim–enforcement–evidence alignment
Security-assurance reviews [40–42]	Claim, requirement, argument, verification evidence	Adapts assurance reasoning to tool-mediated protected effects
Frontier agent-security synthesis [66]	Threat surface, delegated authority, state, evaluation	Used for qualitative positioning, not peer-reviewed denominators

appraisal that connects each asserted property to its obligations, enforcement boundary, observed protected effect, and residual assumptions.

3 Review methodology

3.1 Review design and search boundary

We conducted a structured, claim-centered security review with a coverage cutoff of 15 July 2026. Discovery combined arXiv searches with targeted verification in ACM Digital Library, IEEE Xplore, SpringerLink, ScienceDirect, OpenReview, ACL Anthology, and publisher or proceedings pages, followed by backward and forward citation tracing from recent reviews and included sources. To make the search auditable, the concept search was rerun on 14 September 2026 in arXiv using three exact strings: (1) "LLM agent" AND (authorization OR "access control" OR privilege OR delegation OR revocation); (2) "LLM agent" prompt injection tool security; and (3) "LLM agent" benchmark safety tool. The rerun returned 388 records, 358 unique arXiv identifiers after cross-query deduplication, and 239 records dated on or before the review cutoff. Exact strings, dates, counts, and the retained search records are documented in Supplementary Material 1 (Online Resource 1). The post hoc rerun tests whether the search concept can be rerun under the original cutoff; it does not reconstruct unrecorded historical retrieval counts or define the frozen 75-source evidence library.

The deduplicated evidence library contained 75 sources spanning primary agent studies, access-control and assurance comparators, prior reviews, standards, and horizon literature. Title, DOI, and URL duplicates were checked at record level. Sources entered claim coding only when full text supported an extractable security or assurance claim and allowed the coding team to identify the relevant system boundary, enforcement or evaluation locus, observation point, and obligations. Reviews and standards remained eligible for framing and principle derivation but not for quantitative agent denominators; non-peer-reviewed frontier sources were confined to qualitative horizon positioning.

Screening therefore separated bibliographic retention from analytical inclusion. All 75 source-level decisions and source-specific reasons are reported in Online Resource 1. Figure 1 presents two distinct tracks: (i) the original frozen evidence library (75 assessed sources, 30 claim-coded and 45 retained outside coding) and (ii) the post hoc reproducibility audit (388 retrieved, 358 unique identifiers, and 239 cutoff-eligible records). The 45 non-coded sources comprise 15 reviews or syntheses, 12 contextual or supporting sources with no distinct analytical contribution beyond the coded corpus, 10 foundations or standards, and 8 horizon sources.

3.2 Layered analytical corpus

Thirty sources met the claim-coding criteria and were frozen after a 12-source pilot. Layer A comprises 15 peer-reviewed, agent-specific sources with extractable security claims and sufficient enforcement or evidence semantics; it supplies the primary agent denominator. Layer B contains six agent-relevant sources that fail one strict criterion and are used only in labeled sensitivity analyses. Layer C contains nine authorization or assurance comparators that derive or test relevant obligations but never enter agent proportions. Table 2 defines these roles.

Table 3 lists every coded source, its layer, and its classification basis. Full bibliographic, screening, and SCR-level details are supplied in Online Resource 1.

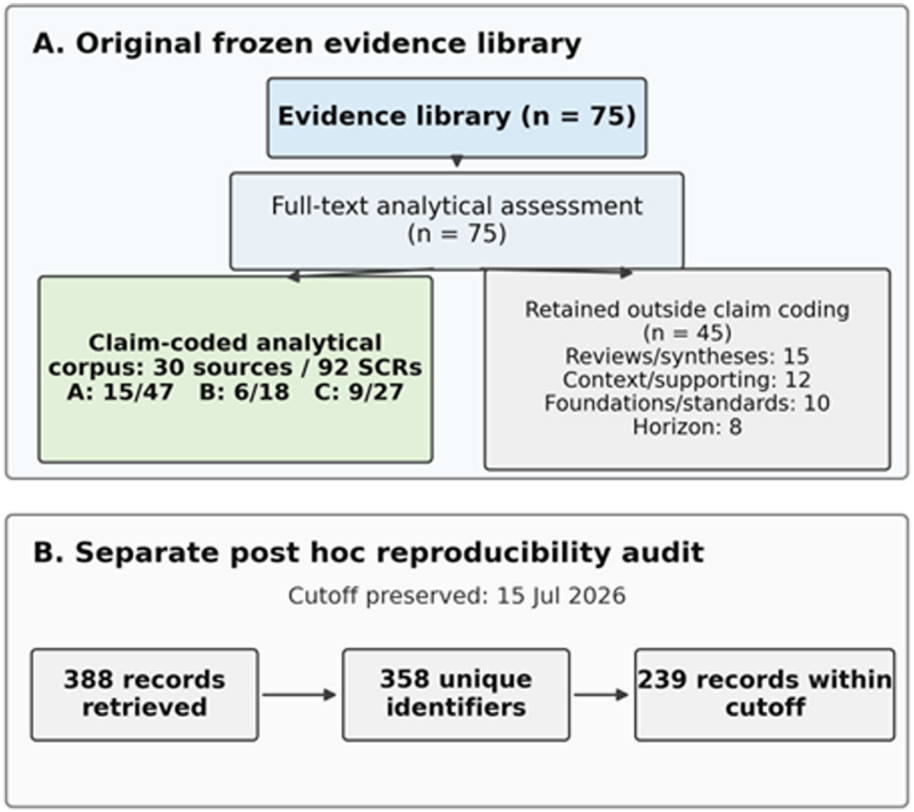


Fig. 1 Original study-selection path and separate post hoc search reproducibility audit. The upper track reports the frozen evidence library and analytical selection; the lower track reports the cutoff-preserving rerun. The rerun tests reproducibility of the search concept and does not reconstruct the historical retrieval that produced the 75-source library

Table 2 Analytical corpus and inferential roles

Layer	Sources	SCRs	Inferential role
A—strict agent evidence core	15	47	Primary source-level denominator for agent findings
B—expanded sensitivity evidence	6	18	Added only in explicitly identified A+B sensitivity analyses
C—authorization/assurance comparators	9	27	Derives or tests obligations; excluded from agent proportions
Total	30	92	Closed claim-coded evidence base

3.3 Source–claim records and appraisal

The SCR, rather than the publication, is the unit of analysis. A source yields multiple records only when it advances claims with different properties, enforcement boundaries, or evidence. Each SCR identifies the source and claim location, paraphrased claim, normalized property, claim scope, system and threat boundaries, principal and delegation relation, protected resource and privileged effect, PDP/PEP location, enforcement timing, bypass and failure behavior, revocation semantics, evidence type and observation point, obligations, residual gap, assumptions, and appraisal.

Extraction separated the authors' claim from the review's normalized interpretation. Terms were mapped to a frozen codebook; narrow claims were not upgraded because a mechanism appeared capable of more. Evidence was coded at the furthest stage directly observed, and benchmark-bounded consequential effects were classified as partial effect-level evidence unless they mapped to an external protected resource.

For claim (c), the required obligations, evidenced obligations, and residual assurance gap are:

$$G(c) = O(c) - E(c)$$

O(c) is the set of obligations required by the claimed property; E(c) is the set supported by reported evidence; and G(c) is the residual assurance gap—the obligations in O(c) that are not supported in E(c).

G(c) is a set, not a scalar score. Formal proof, classification, call observation, sandbox execution, final-state checks, and deployment observation were therefore coded separately.

Table 3 Coded-source characteristics and layer assignments

References	Source	Layer	Classification basis
[1]	From threat to trust: assessing security risks of agentic AI systems	B-Expanded sensitivity evidence	Sensitivity: peer-reviewed agent-risk study that informs system-boundary analysis but does not evaluate a specific authorization control or protected-resource effect
[39]	Structuring trust: a quantitative and traceable framework for hardware security assurance	C-Authorization/assurance comparator	Comparator: supplies claim-to-requirement-to-verification traceability semantics
[71]	Comparative evaluation of machine learning methods for protecting LLMs from prompt injection attacks	B-Expanded sensitivity evidence	Sensitivity: prompt-injection detector comparison whose evidence terminates at classifier output rather than an agent execution or protected-resource effect
[48]	Fine-grained access control for multi-user data in cooperative systems: managing compound objects and temporal constraints	C-Authorization/assurance comparator	Comparator: supplies fine-grained and temporal authorization obligations
[49]	Graph-based formal modeling and implementation of access control policies with automated conflict and redundancy detection	C-Authorization/assurance comparator	Comparator: supplies formal policy-conflict and redundancy semantics
[34]	Using the ACE framework to enforce access and usage control with notifications of revoked access rights	C-Authorization/assurance comparator	Comparator: directly measures downstream denial after revocation
[50]	A novel risk-based access control engine in zero trust architecture for IoT network	C-Authorization/assurance comparator	Comparator: contributes dynamic risk-state and temporal access-control semantics
[26]	Permissive Information-Flow Analysis for Large Language Models	A-Strict agent evidence core	Peer-reviewed agent/tool study with extractable information-flow control claims
[72]	PPLLA: Privacy-preserving attribute-based LLM authorization	B-Expanded sensitivity evidence	Sensitivity: authorization-specific LLM gateway protocol
[35]	OPMonitor: Continuously monitoring residual over-granted permissions in verified access control policies	C-Authorization/assurance comparator	Comparator: measures residual over-grant relevant to effective least privilege
[70]	sec-certs: Examining the security certification practice for better vulnerability mitigation	C-Authorization/assurance comparator	Comparator: links certification evidence to later vulnerability information
[60]	Enforcing cryptographic distributed-VCS access control with no trust on servers	C-Authorization/assurance comparator	Comparator: binds authorization to cryptographic peer/resource acceptance
[61]	DRAC: A dynamic fine-grained access control scheme for cloud storage with censorship-coerced resistance	C-Authorization/assurance comparator	Comparator: contributes fine-grained revocation and cryptographic enforcement semantics
[20]	AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents	A-Strict agent evidence core	Peer-reviewed agent/tool study with extractable prompt injection; tool-agent security claims
[21]	AgentPoison: Red-teaming LLM Agents via Poisoning Memory or Knowledge Bases	A-Strict agent evidence core	Peer-reviewed agent/tool study with extractable persistent state; memory poisoning claims
[67]	Identifying the Risks of LM Agents with an LM-Emulated Sandbox	A-Strict agent evidence core	Peer-reviewed agent/tool study with extractable sandbox risk evaluation claims

Table 3 (continued)

References	Source	Layer	Classification basis
[22]	Tensor Trust: Interpretable Prompt Injection Attacks from an Online Game	B-Expanded sensitivity evidence	Sensitivity: prompt-injection benchmark whose main evidence terminates at model/application output rather than tool execution or protected state
[68]	Agent Security Bench (ASB): Formalizing and Benchmarking Attacks and Defenses in LLM-based Agents	A-Strict agent evidence core	Peer-reviewed agent/tool study with extractable attack/defense benchmark; tool use claims
[69]	AgentHarm: A Benchmark for Measuring Harmfulness of LLM Agents	A-Strict agent evidence core	Peer-reviewed agent/tool study with extractable harmful multi-step tool use claims
[36]	τ-bench: A Benchmark for Tool-Agent-User Interaction in Real-World Domains	A-Strict agent evidence core	Peer-reviewed agent/tool study with extractable policy-guided tool use; final state claims
[27]	Optimizing Agent Planning for Security and Autonomy	A-Strict agent evidence core	Peer-reviewed agent/tool study with extractable ifc; security/autonomy claims
[23]	StruQ: Defending Against Prompt Injection with Structured Queries	A-Strict agent evidence core	Peer-reviewed agent/tool study with extractable prompt injection; structured channels claims
[73]	AirGapAgent: Protecting Privacy-Conscious Conversational Agents	A-Strict agent evidence core	Peer-reviewed agent/tool study with extractable task-scoped data access claims
[64]	IPIGuard: A Novel Tool Dependency Graph-Based Defense Against Indirect Prompt Injection in LLM Agents	A-Strict agent evidence core	Peer-reviewed agent/tool study with extractable tool dependency; indirect injection claims
[24]	InjecAgent: Benchmarking Indirect Prompt Injections in Tool-Integrated Large Language Model Agents	A-Strict agent evidence core	Peer-reviewed agent/tool study with extractable indirect prompt injection; tools claims
[37]	ToolSandbox: A Stateful, Conversational, Interactive Evaluation Benchmark for LLM Tool Use Capabilities	B-Expanded sensitivity evidence	Sensitivity: stateful tool-use benchmark with trajectory and state evidence, but authorization security is not its primary evaluation objective
[28]	Defeating Prompt Injections by Design	A-Strict agent evidence core	Peer-reviewed agent/tool study with extractable capabilities; ifc; prompt injection claims
[65]	Towards Verifiably Safe Tool Use for LLM Agents	A-Strict agent evidence core	Peer-reviewed agent/tool study with extractable safety requirements; capabilities; mcp claims
[74]	Translating Natural Language Specifications into Access Control Policies by Leveraging Large Language Models	B-Expanded sensitivity evidence	Sensitivity: offline natural-language-to-policy translation
[62]	WASP: Benchmarking Web Agent Security Against Prompt Injection Attacks	A-Strict agent evidence core	Peer-reviewed agent/tool study with extractable web-agent prompt injection; realized effects claims

Pilot coding from 16–28 July 2026 generated 38 SCRs across six property families, exceeding the predefined feasibility gate of 25 records across four families. The corpus and codebook were then frozen, and all 30 sources were coded to 92 SCRs: 47 in Layer A, 18 in Layer B, and 27 in Layer C

Table 4 Operational elements and inferential boundaries

Element	Coding question	Inferential boundary
Claim and property	What is asserted, prevented, or guaranteed?	A mechanism label is not itself an assurance claim
Principal and delegation	Whose authority is exercised, by whom, and under what scope/duration?	User intent does not automatically bind downstream execution
Protected resource/effect	What security-relevant state transition matters?	Tool selection or submission may precede the realized effect
PDP and PEP	Where is permission decided and where is it enforced?	Decision correctness does not prove path coverage
Enforcement timing	Is authority constrained at provisioning, task, call, execution, resource, or revocation time?	Static reduction is not per-operation authorization
Evidence and observation	What is proved/tested, and at which stage?	Later stages are not universally superior; fit depends on the claim
Residual assumptions	What remains trusted, synchronized, non-bypassable, or outside attacker control?	Assumptions bound assurance but do not automatically invalidate it

A source was appraised as aligned, partially aligned, or misaligned according to whether its evidence supported the obligations implied by its own claim scope.

3.4 Quality assurance and synthesis

After primary coding, 20 of 92 SCRs (21.7%) were selected through a two-stage stratified design. The sample deliberately represented all corpus layers (12/47 Layer A, 4/18 Layer B, and 4/27 Layer C) and nine of the ten property categories instantiated in the dataset; reliability-under-repetition was the only instantiated category not sampled. Within the layer-property strata, records were drawn without replacement by computer and were not selected on expected agreement.

The independent second coding was performed by Dr Mohamed Hassan, Professor at the Faculty of Computers and Information, Fayoum University, Egypt. He holds a PhD in Computer Science and has more than 15 years of research experience, including information security. He received the frozen codebook and a blinded 20-record packet without the first coder's classifications and coded the sample independently during 17–22 August 2026.

Across four judgment-bearing fields, pre-adjudication agreement was 100% for normalized property ($\kappa = 1.000$), 90% for enforcement locus ($\kappa = 0.861$), 90% for observation stage ($\kappa = 0.885$), and 95% for effect-level evidence ($\kappa = 0.899$). Five of 80 decisions differed. The two coders first re-applied the frozen definitions to distinguish interpretive differences from terminology mismatches and then reached codebook-grounded consensus. No disagreement affected normalized property or a corpus-level denominator; all original labels and resolutions remain visible in Online Resource 1.

Layer A supplies the primary source-level agent denominator. The A+B condition is the explicit borderline-source reclassification analysis: all six Layer-B sources are treated as included agent evidence and the principal findings are recalculated under that expanded boundary. The principal conclusions remain unchanged under this reclassification. Layer C never enters agent proportions. Additional sensitivity checks retain the second coder's alternative boundary labels for the five disputed decisions and report the effect of the benchmark-bounded CaMeL classification. No pooled statistic treats the 92 SCRs as independent studies. Zero counts mean no evaluable coded claim within the closed corpus, not absence of a control in deployed systems.

4 Authorization assurance claim model

Authorization assurance is interpreted relative to an operational execution chain and an evidentiary claim chain. A principal is the entity whose authority is recognized; an actor is the agent, sub-agent, service, or executor exercising it. A protected resource is the state or service over which authority is exercised, and a privileged effect is the realized security-relevant consequence at that resource. The PDP decides whether an operation is permitted; the PEP must constrain the path that can realize it.

Intermediate events and protected effects are not interchangeable. A generated command may never execute; an admitted tool call may fail or partially commit; and a correct final state may still have been reached through an unauthorized sequence. Enforcement may occur at provisioning, task start, planning, call admission, execution, resource access, or after revocation, so claim scope determines which link must be observed. (Fig. 2).

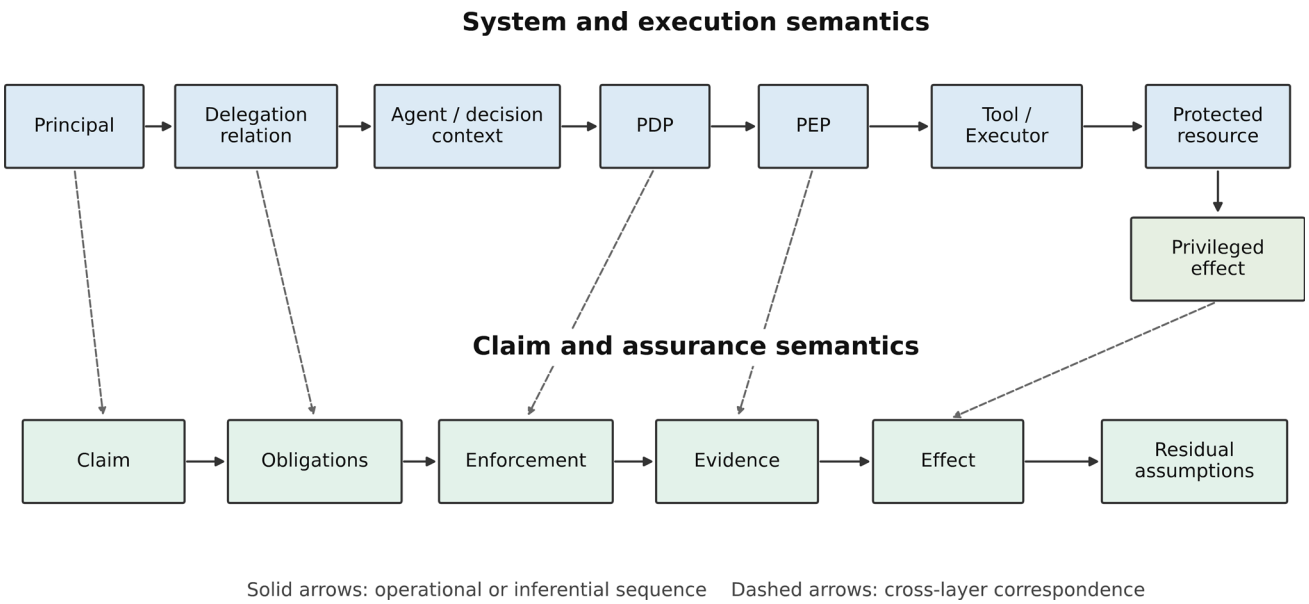


Fig. 2 Authorization Assurance Claim Model. The upper path shows delegated authority reaching a protected resource; the lower path shows the assurance argument used to appraise the corresponding claim

Table 4 summarizes the operational elements and their inferential boundaries. The analytical chain is:

Table 5 consolidates the property-specific obligations and the evidence needed for stronger claim scope.

$$\begin{aligned}\text{Principal} \rightarrow \text{Delegation} \rightarrow \text{Actor/Agent} \rightarrow \text{PDPdecision} \rightarrow \\ \text{PEPenforcement} \rightarrow \text{Tool/Executor} \rightarrow \text{Protected resource} \rightarrow \text{Privileged effect}\end{aligned}$$

Evidence is located at six stages: plan, tool selection, tool call, execution, final state, and deployment effect. Each can support a bounded claim at that stage, but later causal consequences require either direct observation or an explicit correspondence argument. A final-state oracle is effect-proximate only to the predicates it encodes.

Residual assumptions are first-class model elements. Common assumptions concern tool visibility, capability labels, non-bypassability, credential binding, environment fidelity, policy freshness, executor behavior, and trusted humans or components. Recording them bounds the inference without treating their existence as evidence of insecurity.

5 Property-specific assurance obligations

The model becomes appraisable when each claimed property determines O(c). Obligations are claim-contingent: a decision-accuracy study need not test revocation unless it claims revocable authority, while a complete-mediation claim must address every in-scope path to the specified effect.

Least privilege concerns effective authority, not only the number of visible tools:

$$\text{Task} - \text{required(c)} \leq \text{Exercised(c)} \leq \text{Available(c)} \leq \text{Granted(c)}$$

Complete mediation requires every in-scope path to the specified effect to traverse the PEP, and non-bypassability requires the agent to be unable to evade or mutate that control. Evidence must also match the claimed effect: model classification can support classifier accuracy, whereas a resource-effect claim requires execution/state evidence or a justified correspondence argument.

Authorization correctness further requires an identifiable relation among principal, resource, operation, and context. Delegation, temporal validity, fail-safe behavior, and accountability add conditional obligations only when those properties are claimed; logs support reconstruction but do not substitute for preventive enforcement.

Table 5 Property-specific obligations and minimum claim-aligned evidence

Claimed property	Core obligations	Evidence needed for the stronger claim	Insufficient proxy
Authorization correctness	Policy, principal, resource, operation, context, correct allow/deny, decision bound to action	Decision evidence for decision claims; execution/state evidence for enacted compliance	Policy QA or classifier accuracy without enforced execution
Least privilege	Task-required versus granted/available/exercised authority; argument/resource granularity; adjacent or dynamic authority	Effective-authority comparison across in-scope operations	Smaller tool list without showing task-minimal remaining authority
Complete mediation	Protected effect; all in-scope paths; mandatory PEP traversal; alternative paths; active enforcement	Path-coverage argument plus observation appropriate to the effect	Rejection at one gateway with untested routes
Non-bypassability	PEP outside agent discretion; decision bound to execution; credential and alternate-route resistance	Formal argument or adversarial bypass testing within the threat model	Correct behavior only through the intended interface
Fail-safe enforcement	Defined failures; deny/safe default; safe partial operations and recovery	Failure injection or formal coverage of material failure modes	Nominal-operation accuracy
Delegation containment	Original principal; delegated scope; attenuation; chain integrity; credential binding; redelegation and expiry	Downstream authority/effects remain within delegated scope	Fewer named permissions without effect-level containment
Temporal validity/revocation	Revocation event and effective time; stale/cached authority; propagation; latency; in-flight operations	Post-revocation execution or resource-side denial	Central invalidation without subsequent access test
Accountability/traceability	Link principal, delegation, policy, PEP, operation, credential, time, and effect	Reconstructable and integrity-protected principal–policy–action–effect trace	Tool-call log without effect or provenance

The obligations prevent two symmetric errors: extending upstream evidence to an unobserved protected effect, and judging a narrow, correctly evidenced claim against a stronger property it never asserted

6 Landscape of authorization claims

The 21 agent-focused sources comprised nine benchmark/evaluation sources [20, 22, 24, 36, 37, 62, 67–69], ten mechanism, control, authorization, or policy-engineering sources [23, 26–28, 64, 65, 71–74], and two threat/risk studies [1, 21]. These roles overlap conceptually but describe why each source entered the analysis. Layer C supplied comparators only.

Across the 47 Layer-A SCRs, 14 concerned preventive properties—five complete mediation/non-bypassability, four information-flow control, three least privilege/data minimization, one policy compliance, and one fail-safe behavior. The remaining 33 concerned evidence-to-effect alignment, threat/boundary coverage, reliability, or claim–enforcement traceability. Expansion to A+B produced 65 agent-focused SCRs but no revocation or delegation-containment record. (Table 6).

The imbalance is substantively informative but must be interpreted carefully. It shows that the selected agent evidence base says much more about attacks, trajectories, calls, and evaluation boundaries than about several classical authorization properties. It does not show that every paper should have claimed revocation, delegation containment, or fail-safe behavior. Rather, it identifies which assurance questions cannot be answered from the claims and observations currently represented in the corpus.

Systems ranged from model-facing structured interfaces to wrappers, tool registries, runtime guards, persistent memory, executable tools, and stateful web environments. Delegation was usually implicit in a user assigning a task while the agent exercised application capabilities, rather than

Table 6 Property coverage in the agent-focused corpus

Property/dimension	Layer A sources	Layer A+B sources	Principal interpretation
Policy compliance	1	4	Decision and process semantics are sparsely explicit
Least privilege/data minimization	3	3	Pre-execution authority or data narrowing
Complete mediation/non-bypassability	5	5	Different enforced boundaries and observation points
Fail-safe behavior	1	2	Rarely evaluated as an independent property
Delegation containment	0	0	No evaluable agent-focused claim
Revocation/temporal validity	0	0	No evaluable agent-focused claim
Confidentiality/integrity information flow	4	4	Wrapper, guard, interpreter, or structured interface
Evidence-to-effect alignment	15	21	Cross-cutting dimension represented in every agent source

represented as an authorization object with scope, attenuation, redelegation, and revocation. Threat models also differed: injected content [22–24, 28, 62, 64], poisoned memory [21], underspecified benign tasks [67], direct malicious requests [69], and trusted planner, metadata, interpreter, or human assumptions [27, 28, 65]. These differences preclude treating all SCRs as measurements of one homogeneous security construct.

Protected resources included private information, memory and retrieval state, tool/application databases, authenticated web resources, authorization labels, and policy representations. Corresponding effects ranged from disclosure to message transmission, record modification, harmful multi-step completion, and attacker-defined web state. This diversity is not noise to be normalized away: it determines whether a reported observation is semantically close enough to the effect named by the claim.

7 Enforcement semantics

Enforcement ranged from early authority reduction to runtime interception and resource/cryptographic acceptance. AgentDojo filters tools before untrusted content is processed [20]; AirGapAgent minimizes data disclosed to an untrusted conversational component [73]; and IPIGuard constrains a precomputed command-tool dependency graph while permitting limited query-tool expansion [64]. These are meaningful reductions, but tool availability, accessible data, and operation-level authority are not equivalent.

Runtime mechanisms place the control closer to execution. The IFC guard in [27] checks consequential calls and permits, blocks, or escalates them. CaMeL mediates calls through a capability/provenance interpreter [28]. The design in [65] requires an independent interceptor and evaluates modeled traces. Moving control outside unconstrained agent reasoning improves the non-bypassability argument, but each guarantee remains bounded to instrumented tools, registered capabilities, correct metadata, or the modeled architecture. (Table 7).

Tool granularity is a recurring boundary. A shared tool may perform authorized and unauthorized operations depending on target, argument, state, or time. AgentDojo notes the limitation when benign and malicious goals require the same tool [20]; IPIGuard remains dependent on tool classification and graph completeness [64]; and ASB's simplified calls can omit argument semantics [68]. Conventional access control makes these dimensions explicit and demonstrates that a valid policy can retain residual over-grant [9, 35, 48].

Five Layer-A sources produced mediation/non-bypassability claims [27, 28, 64, 65, 73]. All provided controls stronger than prompt-only instruction, but none supports an unbounded field-wide conclusion. Uninstrumented APIs, unregistered tools, hidden resource channels, mutable metadata, or trusted-component compromise remain outside some boundaries. Fail-safe behavior was even sparser: [26] assigns missing labels the most restrictive value, while [74] addresses ambiguity in policy translation rather than runtime fail-closed execution. No agent source evaluated downstream revocation.

Table 7 Representative enforcement patterns and assurance boundaries

Pattern	Sources	PEP location	Supported scope	Main boundary
Pre-task tool reduction	[20]	Tool registry	Bounded authority reduction	Shared tools and arguments remain
Pre-interaction data minimization	[73]	Trusted data boundary	Bounded disclosure/least privilege	Minimizer correctness and hidden access
Tool-dependency restriction	[64]	Agent executor	Bounded mediation/least privilege	Classification and graph completeness
Structured instruction/data separation	[23]	Front end plus model	Interface-level integrity	Model remains part of the control
Runtime IFC guard	[27]	Instrumented calls	Call-time information-flow mediation	Consequential effects must use instrumented tools
Capability/provenance interpreter	[28]	Interpreter	Formal and implemented bounded mediation	Registered tools, metadata, interpreter trusted
Independent formal interceptor	[65]	Modeled call boundary	Non-bypassability in the model	Runtime implementation pending
Gateway/cryptographic comparator	[60, 61, 72]	Gateway or resource/protocol boundary	Authorization or revocation within protocol scope	Downstream agent-tool effects may be outside scope

The PDP–PEP distinction also separates policy specification from enforced execution. PPLLA establishes privacy-preserving attribute matching within an LLM gateway under an explicit cryptographic threat model [72], but downstream tool effects remain outside that protocol. The natural-language policy study in [74] evaluates extraction of entities and relations without executing the resulting rules against a protected resource. Conversely, Layer-C mechanisms such as distributed version-control access control [60] bind decisions more directly to cryptographic read/write acceptance. The relevant appraisal question is therefore not whether a policy exists, but whether its decision is bound to the operation whose effect is claimed.

Enforcement timing creates another non-equivalence. A control applied before task execution may prevent unnecessary capabilities from entering the interaction, while a call-time PEP can incorporate current arguments and context. Resource-time enforcement can remain independent of the agent's reasoning, but it may know less about task intent or upstream delegation. No location is automatically sufficient: assurance depends on whether the location has the information and control required by the claimed property. Robust designs may therefore compose early minimization, call-time checks, and resource-side authorization rather than asking one layer to carry the entire assurance argument.

The central enforcement result is therefore semantic rather than numerical: policy specification, decision correctness, capability reduction, call interception, and resource-side denial are distinct security propositions.

8 Security evidence and observation points

Evidence in the corpus included conceptual risk analysis, formal reasoning, offline model or policy evaluation, call-level benchmarks, emulated execution, stateful environments, and rule-verified effects. Formal evidence can strongly justify an in-model property without establishing implementation correspondence; executable evidence can demonstrate concrete behavior without proving universal path coverage [39, 41, 42].

Offline evidence terminated at prompt classification, model response, or generated policy in [22, 23, 71, 74]. ASB and InjecAgent observed tool selection or parsed invocation [24, 68]. ToolEmu executed stateful emulated trajectories and validated realism through human judgment [67]. AgentDojo, τ-bench, and ToolSandbox inspected environment or database state [20, 36, 37], while WASP separated an intermediate hijack judge from a rule-based attacker-goal predicate [62]. AgentPoison similarly separated poisoned retrieval, target action, and end-to-end impact [21]. (Fig. 3).

No Layer-A or Layer-B source provided longitudinal production-deployment authorization evidence. This absence bounds generalization but does not make controlled evidence weak. A rule-based final-state oracle can strongly establish whether a defined effect occurred in the tested environment while remaining silent about other environments, causal paths, or unencoded authorization conditions. (Table 8).

Effect proximity and semantic completeness must also be separated. A final-state checker can directly observe whether

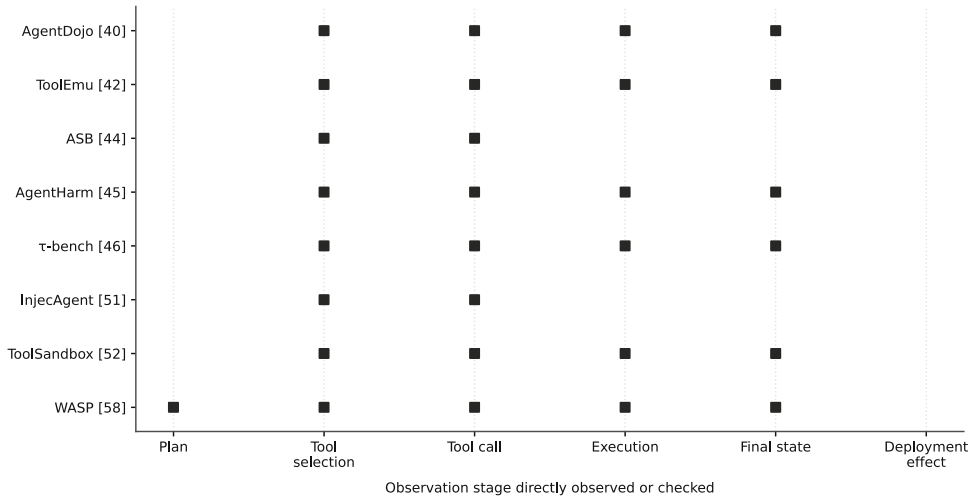


Fig. 3 Observation coverage in representative agent-security benchmarks. ASB and InjecAgent terminate at tool-call observation; dots identify stages directly observed or checked and do not constitute a quality ranking

Table 8 Cross-cutting findings and denominators

Finding	Basis	Main inference
Mediation evidence is not uniformly effect-level	Five Layer-A sources	Do not generalize beyond the enforced boundary
Least privilege is authority narrowing	3/3 relevant Layer-A sources	Tool/data reduction supports a bounded claim
No agent revocation-assurance claim	0/21 A+B sources	Coverage gap, not demonstrated system failure
No delegation-containment claim	0/30 analytical sources	Coverage gap requiring direct evaluation
Final state $\neq$ authorization correctness	Counterexample synthesis [36, 37]	State and process predicates are both required
Residual assumptions are universal	15/15 Layer-A sources	Guarantee scope depends on explicit assumptions
Assurance is compositional	[27, 28, 62, 65] plus [39, 41, 42, 70]	Formal, runtime, and effect evidence are complementary

a database changed, but it may not encode which principal initiated the action, whether the user confirmed it, whether the correct policy version applied, or whether the change followed a permitted sequence. Conversely, a formal proof at a call boundary can provide strong coverage of modeled traces while remaining upstream of real service behavior. Security evidence is strongest when these distinct contributions are connected rather than treated as substitutes.

The same distinction applies within empirical studies. A parsed model output may be a reliable representation of an attempted call yet remain dependent on the assumption that the call would execute. An emulated environment can test stateful trajectories while depending on fidelity to external services. A self-hosted application can verify a concrete final state while remaining bounded to enumerated actions and attacker goals. These are not defects in the studies; they are boundaries that determine which authorization claim the evidence can justify.

Evidence adequacy therefore depends on the claim. Detector output can support detector accuracy [71]; call admission can support interception [27, 28]; protected-state observation is necessary for a claim about record modification [36, 37, 62]; and post-revocation resource access is necessary for a claim that authority ended [34]. This claim-relative interpretation replaces a universal evidence ladder.

9 Cross-cutting authorization-assurance findings

9.1 Finding 1: mediation evidence does not uniformly terminate at the protected effect

Five strict-agent sources contained complete-mediation or non-bypassability claims [27, 28, 64, 65, 73], but their controls and evidence terminated at different boundaries. CaMeL provides formal-plus-implementation evidence inside a

registered-tool interpreter [28], whereas [65] provides modeled intercepted-trace evidence without runtime implementation. These are different bounded claims: call interception supports mediation of the tested path; effect-level complete mediation additionally requires evidence that the enforced boundary is exhaustive and unavoidable.

9.2 Finding 2: least privilege is operationalized as authority narrowing

Exactly three Layer-A sources generated least-privilege/data-minimization SCRs [20, 64, 73]. All 3/3 narrowed tools, data, or command paths before or early in execution, and none measured effective privilege across the complete trajectory. The result applies only to these three evaluable sources. It identifies a concrete measurement need: compare task-required, granted, available, and exercised authority while testing shared tools, arguments, dynamic expansion, adjacent resources, and alternate credentials.

9.3 Finding 3: revocation and delegation containment are coverage gaps

No evaluable revocation-assurance claim appeared in Layer A or after expansion to all 21 agent-focused sources (0/21), and no delegation-containment or attenuation claim appeared in the 30-source corpus (0/30). These are corpus-bounded claim-coverage gaps, not evidence that deployed controls are absent. Comparator evidence indicates the needed tests: post-revocation attempts, stale-credential use, propagation to subagents, actor substitution, attenuation across handoffs, and downstream denial [11–13, 34, 50, 61].

9.4 Finding 4: final-state correctness is not authorization correctness

τ-bench shows that an expected database state can be reached through a policy-violating sequence, including omitted confirmation [36]; ToolSandbox supports milestones and minefields without generally encoding mandatory authentication and confirmation [37]. Authorization benchmarks therefore need paired oracles over protected-state consequences and the legitimacy of identity, consent, order, time, and delegation:

$$\mathrm{Final-state}(c) = \mathrm{Pass} \not\Rightarrow \mathrm{Authorization-correct}(c) = \mathrm{Pass}$$

Effect proximity and semantic completeness are independent. Final-state predicates cannot establish unencoded identity or process obligations, while call admission cannot confirm the realized resource consequence.

9.5 Finding 5: residual assumptions bound every strict-agent argument

At least one material residual assumption was recorded for every Layer-A source (15/15), including wrapper visibility, benchmark fidelity, emulator realism, trusted planners or humans, structured-channel preservation, hidden-access exclusion, capability metadata, and implementation correspondence [20, 23, 26–28, 62, 64, 65, 67–69, 73]. This prevalence is an expected consequence of explicitly coding trusted boundaries, not a surprising defect rate. Its value is to distinguish stated, bounded assumptions from silent extensions of claim scope.

9.6 Finding 6: strong assurance is compositional

The corpus does not support a universal ranking of formal proof, sandbox execution, or final-state evidence. CaMeL combines formal semantics, implementation, and benchmark testing [28]; [27] combines runtime enforcement with benchmark evidence; [65] offers bounded formal evidence with implementation pending; and WASP supplies rule-verified effects in defined environments [62]. Strong assurance is compositional correspondence among property, obligations, enforcement, evidence, effect, and assumptions; no modality substitutes for a link it does not establish. (Fig. 4).

10 Benchmarks, auditability, and reproducibility

Benchmark meaning depends on the oracle. AgentDojo combines deterministic task checks, environment mutations, attacker success, and benign utility [20]. ASB operationalizes many attacks through attack-specific tool use and simplified calls [68]. InjecAgent parses harmful or exfiltration-oriented calls and simulates responses [24]. AgentHarm scores multi-step completion through proxy tools and task-specific rubrics [69]. ToolEmu adds stateful emulation and realism validation [67]. These designs answer different questions and should not be collapsed into a single attack-success construct.

Stateful benchmarks improve effect observability but can omit authorization semantics. τ-bench checks final database state and selected outputs and uses (passˆk) to expose repeated-run instability [36]; ToolSandbox represents multiple valid trajectories through milestones and prohibited intermediate conditions [37]; WASP distinguishes intermediate diversion from a rule-verified attacker goal [62]. A benchmark can therefore be close to the effect yet incomplete with respect to identity, consent, delegation, or policy version.

Trace availability is not itself an auditability guarantee. A useful authorization trace links principal, delegation,

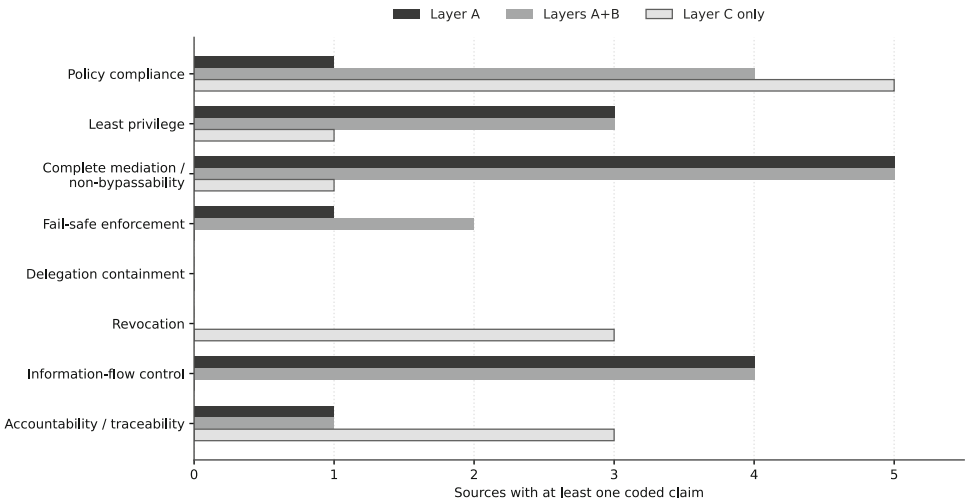


Fig. 4 Property coverage across the closed analytical corpus. Counts represent sources with at least one coded claim and are not field-wide prevalence estimates

policy version, PDP decision, PEP action, credential, operation arguments, and protected effect. Existing benchmarks expose fragments of this chain; none in A+B claims complete authorization auditability, and the only strict-corpus traceability record arose from [65]. Preserving these fields also allows later users to reconstruct why an oracle classified a trajectory as authorized, unauthorized, successful, or failed [39, 41, 42, 70].

Reproducibility depends on preserved security semantics as well as released code. Tool schemas, simulated responses, database state, model versions, predicates, rubrics, and evaluator prompts can change score meaning. Portability therefore requires re-establishing the link between the oracle and the protected effect. Task success, attack success, and authorization compliance remain distinct. (Table 9).

Repeated-run behavior deserves separate attention. Only τ-bench generated a dedicated strict-corpus reliability record through (passˆk) [36]. A control that blocks an unauthorized effect in 95% of runs but intermittently allows it has a different security interpretation from an agent that merely fails benign tasks in the remaining runs. Mean task or attack scores can obscure this asymmetry; security-sensitive evaluation should report failure distributions and worst-case or repeated-run behavior where feasible.

11 Minimum authorization-assurance profile

The synthesis produces the Minimum Authorization-Assurance Profile (MAAP), a preliminary, review-derived minimum reporting framework. Its contribution is not invention of least privilege, complete mediation, fail-safe defaults, delegation, revocation, or traceability; those principles are established [7–13, 34, 35, 39, 41, 42, 48–51, 70, 75]. MAAP integrates and operationalizes them for tool-using LLM agents by mapping each disclosure to the coded claim-enforcement-evidence gaps in this review.

Core elements apply to every authorization-assurance claim; conditional elements apply only when the corresponding property is asserted. An element is minimum when omitting it would prevent a reader from identifying claim scope, locating enforcement and evidence, or evaluating a property-specific obligation. MAAP is a disclosure structure, not a scalar score, certification scheme, or validated assurance instrument. Table 10 traces each element to both prior principles and review findings.

MAAP does not require every study to address every security property. It requires the supported claim to remain within the joint boundary of its mechanism and evidence. Path coverage cannot replace post-revocation testing when revocation is claimed, and final-state evidence cannot establish an identity obligation absent from the oracle.

MAAP's current contribution is methodological rather than predictive. Independent work should test its inter-rater applicability, sensitivity to known mismatches, usability for authors and evaluators, completeness, and association with successful reproduction or deployment-relevant gap detection.

12 Discussion and research implications

The review shifts attention from policy presence to defensible authorization claims. Mechanism designers should make PDP-PEP binding, argument/resource granularity, alternative paths, and the trusted computing base explicit. For least privilege, the key unit is effective authority over operations, values, resources, credentials, time, and delegated actors, extending conventional residual-overgrant analysis [35]. Prompt-level training may reduce unsafe behavior [22, 23], but only an unavoidable execution boundary can support a mandatory-enforcement claim [27, 28, 65].

Deployers should test whether published assumptions survive dynamic tools, concurrency, retries, partial commits,

Table 9 Benchmark assurance coverage

Benchmark	Primary oracle	Effect proximity	Key authorization boundary
AgentDojo [20]	Deterministic task checks, environment mutations, targeted ASR	High within benchmark	Goal predicates and tool semantics encode the effect
ToolEmu [67]	Emulated stateful trajectory plus evaluator and human validation	Medium–high, simulated	Emulator fidelity to real tool semantics
ASB [68]	Attack-specific tool use and simplified calls	Call-level	Arguments and realized effects may be omitted
AgentHarm [69]	Multi-step proxy trajectory and task rubrics	High within proxy	Synthetic rather than production effect
τ-bench [36]	Final database/output conditions and (passˆk)	High	Final state can omit consent and sequence
InjecAgent [24]	Parsed harmful/exfiltration calls and simulated responses	Call/simulated execution	No independent effect confirmation
ToolSandbox [37]	Intermediate/final milestones and minefields	High	Authentication/confirmation not generally encoded
WASP [62]	Rule-based final attacker state plus intermediate judge	High	Bounded to tested sites and attacker goals

changing credentials, external services, and long-lived state. Evaluators should ask which obligations were required, evidenced, or left assumed and whether public language stays within that boundary.

Benchmark designers should distinguish influence, attempted operation, executed operation, and realized protected effect. AgentPoison and WASP illustrate the value of decomposing the causal chain [21, 62]. Authorization-sensitive oracles should encode identity, consent, ordering, policy version, time, delegation, and state transition where applicable. Repeated-run reliability also matters: intermittent unauthorized effects have a different interpretation from failures that only reduce benign utility [36].

MAAP supports comparison among mechanisms using similar labels but different enforcement or observation boundaries. Formal models define what follows within stated assumptions; executable environments test concrete implementations and attacks [20, 28, 36, 37, 62, 65, 67, 72]. Mature assurance connects both without treating either as a universal proxy.

The resulting agenda is to measure effective privilege; test revocation during active, cached, and delegated sessions; model attenuation and credential forwarding; combine protected-state and process predicates; compose formal, implementation, adversarial, and effect-level evidence; and collect longitudinal deployment evidence. These priorities follow from coded gaps, not from a claim to design a universal agent architecture.

13 Limitations and threats to validity

The 30-source corpus is analytically selected and deliberately bounded. The 15-source strict denominator supports corpus-specific findings, not field-wide prevalence. The 15 July 2026 cutoff is material in a rapidly evolving field, and later work may address revocation or delegation directly. Layer B broadens sensitivity but differs from Layer A on at least one strict criterion; Layer C clarifies obligations but cannot describe agent practice. Horizon sources support positioning only.

The search-audit rerun improves reproducibility, but terminology remains unstable and publisher/proceedings verification plus citation tracing do not have a single database-style retrieval count. Relevant mechanisms may be described through information flow, capability safety, tool security, or policy compliance without using 'authorization.' Exact rerun strings and the 75 source-level decisions are therefore supplied so the corpus can be independently inspected and updated.

SCR construction requires judgment about normalization, system boundary, PDP/PEP location, privileged effect, observation stage, and assumptions. Independent coding supports reproducibility for the 20-record, four-field sample, but not unique interpretation of every record. The sample covered nine of ten instantiated property categories and did not include reliability-under-repetition.

The five pre-adjudication disagreements occurred at adjacent observation, enforcement-locus, or benchmark-bounded effect categories. Consensus followed the frozen codebook

Table 10 Review-derived minimum authorization-assurance profile (MAAP)

Profile element	Status	Minimum disclosure/evidence	Prior principle and review provenance
Security claim and scope	Core	Exact property, boundary, and violation/satisfaction condition	[39, 41, 42]; F1, F6
Principal/actor and delegation relation	Core	Whose authority originates and who exercises it	[8–13, 75]; F3, F4
Protected resource and privileged effect	Core	Resource and security-relevant operation/state transition	[7, 75]; F1, F4
PDP and PEP location	Core	Where authorization is decided and where execution is constrained	[9, 10]; F1, F6
Enforcement timing	Core	Provisioning, task, call, execution, resource, or revocation stage	[11–13, 34, 48, 50, 61]; F1-F3
Evidence type and observation point	Core	What is proved/tested and where it observes the execution chain	[39, 41, 42, 70]; F1, F4, F6
Residual assumptions	Core	Trusted components, paths, metadata, credentials, environment, or humans	[41, 42]; F5
Effective-authority analysis	Conditional: least privilege	Required vs granted vs available vs exercised authority	[7, 35, 75]; F2
Bypass-path coverage	Conditional: mediation/non-bypassability	Alternative tools/APIs, direct paths, credential reuse, argument mutation, sub-agents	[7]; F1
Failure behavior	Conditional: fail-safe	Behavior under unavailable, malformed, partial, ambiguous, or stale authorization state	[7]; sparse-property result
Delegation chain and attenuation	Conditional: delegation	Handoffs, scope reduction, redelegation, credential binding, expiry	[8, 12, 13]; F3
Post-revocation evidence	Conditional: revocation	Event, propagation, latency, stale state, downstream denial	[11–13, 34, 50, 51, 61]; F3
Trace completeness	Conditional: accountability	Reconstructable principal–policy–decision–execution–effect chain	[39, 41, 42, 70]; benchmark/audit analysis

and did not change a normalized property or denominator, but alternative readings remain visible in the supplementary workbook and are included in sensitivity analysis.

Several properties have sparse or zero denominators. Results such as 3/3 least-privilege sources, 0/21 revocation claims, and 0/30 delegation-containment claims are coverage statements within the corpus, not estimates of the complete field. Heterogeneous adversaries and environments further prevent direct equivalence between a failed sandbox attack, a formal protocol result, and a resource-side denial.

Finally, insufficient assurance evidence is not evidence of insecurity. A call-level experiment may leave a final effect unobserved without implying that the effect occurred; a formal result may leave implementation correspondence outside its model without implying an implementation vulnerability. MAAP should therefore be interpreted within the analytical boundary of this review; future validation should examine its completeness, usability, inter-rater behavior, and relationship to deployed security.

14 Conclusion

Across the closed 30-source corpus and 92 SCRs, similar labels concealed different enforcement and evidence boundaries; three evaluable least-privilege sources narrowed authority without measuring trajectory-wide effective privilege; no evaluable agent revocation claim appeared in A+B; no delegation-containment claim appeared in A-C; and final-state correctness remained distinct from authorization correctness. These are corpus-specific coverage and measurement findings, not estimates of the entire field.

MAAP integrates established security principles and the coded gaps as a preliminary, review-derived minimum reporting framework. Its value lies in making claim scope, enforcement, observation, protected effect, and residual assumptions inspectable; independent validation is still required before it can be treated as an assessment instrument. The paper's central distinction is therefore between authorization functionality and the evidence needed to justify an authorization-assurance claim.

That distinction permits strong but bounded claims. It does not demand that every paper prove every property; it demands that the scope of the claim remain commensurate with the mechanism and evidence actually supplied.

Supplementary Information The online version contains supplementary material available at https://doi.org/10.1007/s10207-026-01343-w.

Acknowledgements The author thanks Dr Mohamed Hassan, Professor at the Faculty of Computers and Information, Fayoum University, Egypt, for independently coding the stratified 20-record reliability sample and participating in codebook-grounded reconciliation of disagreements.

Author contribution M A E conceived and designed the review, developed the methodology, curated and analyzed the evidence, prepared the figures and tables, and wrote and revised the manuscript.

Funding Open access funding provided by The Science, Technology & Innovation Funding Authority (STDF) in cooperation with The Egyptian Knowledge Bank (EKB). No funding was received for conducting this study or preparing this manuscript.

Data availability The 75-source evidence library decisions, 30-source characteristics, complete 92-SCR dataset, coding framework, source-property matrix, sensitivity analyses, and independent coding audit are provided with this article as Online Resource 1.

Declarations

Conflict of interests The author declares no competing interests.

Ethics approval Not applicable.

AI statement AI-assisted tools were used to improve language and clarity; the author is fully responsible for the content.

Open Access This article is licensed under a Creative Commons Attribution 4.0 International License, which permits use, sharing, adaptation, distribution and reproduction in any medium or format, as long as you give appropriate credit to the original author(s) and the source, provide a link to the Creative Commons licence, and indicate if changes were made. The images or other third party material in this article are included in the article's Creative Commons licence, unless indicated otherwise in a credit line to the material. If material is not included in the article's Creative Commons licence and your intended use is not permitted by statutory regulation or exceeds the permitted use, you will need to obtain permission directly from the copyright holder. To view a copy of this licence, visit http://creativecommons.org/licenses/by/4.0/.

References

1. Leo, M., Tan, F., Miao, T., Anand, G.: From threat to trust: assessing security risks of agentic AI systems. Int. J. Inf. Secur. (2026). https://doi.org/10.1007/s10207-025-01185-y
2. He, F., Zhu, T., Ye, D., Liu, B., Zhou, W., Yu, P.S.: The emerged security and privacy of LLM agent: a survey with case studies. ACM Comput. Surv. (2025). https://doi.org/10.1145/3773080
3. Xu, Y., Zhuang, Y., Liu, X., Zhang, T., Xiao, B., Xu, X., Jiang, D., Wang, J., Hu, H.: LLM agents security duality: a comprehensive survey of self-security and empowered cybersecurity. Artif. Intell. Rev. (2026). https://doi.org/10.1007/s10462-026-11563-0
4. Chowa, S.S., Alvi, R., Rahman, S.S., Rahman, M.A., Raiaan, M.A.K., Islam, M.R., Hussain, M., Azam, S.: From language to action: a review of large language models as autonomous agents and tool users. Artif. Intell. Rev. (2026). https://doi.org/10.1007/s10462-025-11471-9
5. Khapre, S., Mersha, M.A., Olalekan, Z., Shakil, H., Iskander, S., Moustafa, A., Kalita, J.: Agentic AI systems: a systematic survey of multi-agent architectures, cognitive foundations, interaction, explainability, security, and performance evaluation. Neurocomputing (2026). https://doi.org/10.1016/j.neucom.2026.134049
6. Alqahtani, H., Ahuja, P.: Secure autonomous cyber defense with LLM agents: a systematic review of autonomy, tool-augmented reasoning, and governance constraints. Comput. Electr. Eng. (2026). https://doi.org/10.1016/j.compeleceng.2026.111184

7. Saltzer, J.H., Schroeder, M.D.: The protection of information in computer systems. Proc. IEEE (1975). https://doi.org/10.1109/PROC.1975.9939
8. Sandhu, R.S., Coyne, E.J., Feinstein, H.L., Youman, C.E.: Role-based access control models. Computer (1996). https://doi.org/10.1109/2.485845
9. NIST: NIST SP 800–162: guide to attribute based access control (ABAC) definition and considerations. NIST special publication. https://doi.org/10.6028/NIST.SP.800-162 (2014)
10. NIST: NIST SP 800–207: Zero trust architecture. NIST special publication. https://doi.org/10.6028/NIST.SP.800-207 (2020)
11. IETF: RFC 6749: The OAuth 2.0 authorization framework. IETF RFC. https://www.rfc-editor.org/rfc/rfc6749 (2012)
12. IETF: RFC 8693: OAuth 2.0 token exchange. IETF RFC. https://www.rfc-editor.org/rfc/rfc8693 (2020)
13. IETF: RFC 8705: OAuth 2.0 mutual-TLS client authentication and certificate-bound access tokens. IETF RFC. https://www.rfc-editor.org/rfc/rfc8705 (2020)
14. Model context protocol project: model context protocol (MCP) authorization specification. MCP specification. https://modelcontextprotocol.io/specification/ (2025)
15. OWASP: OWASP Top 10 for LLM applications / agentic security guidance. OWASP guidance. https://genai.owasp.org/ (2025)
16. Das, B.C., Amini, M.H., Wu, Y.: Security and privacy challenges of large language models: a survey. ACM Comput. Surv. (2025). https://doi.org/10.1145/3712001
17. Sheng, Z., Chen, Z., Gu, S., Huang, H., Gu, G., Huang, J.: LLMs in software security: a survey of vulnerability detection techniques and insights. ACM Comput. Surv. (2025). https://doi.org/10.1145/3769082
18. Chen, C., Gong, X., Liu, Z., Jiang, W., Goh, S.Q., Lam, K.-Y.: AI safety landscape for large language models: taxonomy, state-of-the-art, and future directions. Artif. Intell. Rev. (2026). https://doi.org/10.1007/s10462-026-11590-x
19. Moia, V.H.G., Sanz, I.J., Rebello, G.A.F., de Meneses, R.D., Hitaj, B., Lindqvist, U.: LLM in the middle: a systematic review of threats and mitigations to real-world LLM-based systems. Comput. Sci. Rev. (2026). https://doi.org/10.1016/j.cosrev.2026.100916
20. Debenedetti, E., Zhang, J., Balunović, M., Beurer-Kellner, L., Fischer, M., Tramèr, F.: AgentDojo: a dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. NeurIPS **37**, 82895–82920 (2024)
21. Chen, Z., Xiang, Z., Xiao, C., Song, D., Li, B.: AgentPoison: red-teaming LLM agents via poisoning memory or knowledge bases. NeurIPS **37**, 130185–130213 (2024)
22. Toyer, S., Watkins, O., Mendes, E. A., Svegliato, J., Bailey, L., Wang, T., Ong, I., Elmaaroufi, K., Abbeel, P., Darrell, T., Ritter, A., Russell, S.: Tensor trust: interpretable prompt injection attacks from an online game. ICLR. https://arxiv.org/abs/2311.01011 (2024)
23. Chen, S., Piet, J., Sitawarin, C., Wagner, D.: StruQ: defending against prompt injection with structured queries. USENIX security. https://arxiv.org/abs/2402.06363(2025)
24. Zhan, Q., Liang, Z., Ying, Z., Kang, D.: InjecAgent: benchmarking indirect prompt injections in tool-integrated large language model agents. Findings of ACL. (2024). https://doi.org/10.18653/v1/2024.findings-acl.624
25. Liu, Y., Deng, G., Li, Y., Wang, K., Wang, Z., Wang, X., Zhang, T., Liu, Y., Wang, H., Zheng, Y., Zhang, L. Y., Liu, Y.: Prompt Injection Attack against LLM-Integrated Applications. arXiv:2306.05499. https://arxiv.org/abs/2306.05499 (2023)
26. Siddiqui, S. A., Gaonkar, R., Köpf, B., Krueger, D., Paverd, A., Salem, A., Tople, S., Wutschitz, L., Xia, M., Zanella-Béguelin, S.: Permissive information-flow analysis for large language models. Transactions on machine learning research. https://arxiv.org/abs/2410.03055 (2025)
27. Kolluri, A., Sharma, R., Costa, M., Köpf, B., Niessen, T., Russinovich, M., Tople, S., Zanella-Béguelin, S.: Optimizing agent planning for security and autonomy. ICLR. https://arxiv.org/abs/2602.11416 (2026)
28. Debenedetti, E., Shumailov, I., Fan, T., Hayes, J., Carlini, N., Fabian, D., Kern, C., Shi, C., Terzis, A., Tramèr, F.: Defeating prompt injections by design. IEEE SaTML. https://arxiv.org/abs/2503.18813 (2026)
29. Abdelnabi, S., Gomaa, A., Bagdasarian, E., Kristensson, P. O., Shokri, R.: Firewalls to secure dynamic LLM agentic networks. arXiv:2502.01822. https://arxiv.org/abs/2502.01822 (2025)
30. Beurer-Kellner, L., Buesser, B., Creţu, A.-M., Debenedetti, E., Dobos, D., Fabian, D., Fischer, M., Froelicher, D., Grosse, K., Naeff, D., Ozoani, E., Paverd, A., Tramèr, F., Volhejn, V.: Design patterns for securing LLM agents against prompt injections. arXiv:2506.08837. https://arxiv.org/abs/2506.08837 (2025)
31. Costa, M., Köpf, B., Kolluri, A., Paverd, A., Russinovich, M., Salem, A., Tople, S., Wutschitz, L., Zanella-Béguelin, S.: Securing AI agents with information-flow control. arXiv:2505.23643. https://arxiv.org/abs/2505.23643 (2025)
32. Wang, S., Zhang, G., Yu, M., Wan, G., Meng, F., Guo, C., Wang, K., Wang, Y.: G-Safeguard: a topology-guided security lens and treatment on LLM-based Multi-agent systems. Proceedings of the 63rd annual meeting of the association for computational linguistics, pp. 7261–7276. (2025). https://doi.org/10.18653/v1/2025.acl-long.359
33. Wallace, E., Xiao, K., Leike, R., Weng, L., Heidecke, J., Beutel, A.: The instruction hierarchy: training LLMs to prioritize privileged instructions. arXiv:2404.13208. https://arxiv.org/abs/2404.13208 (2024)
34. Rasori, M., Saracino, A., Mori, P., Tiloca, M.: Using the ACE framework to enforce access and usage control with notifications of revoked access rights. Int. J. Inf. Secur. (2024). https://doi.org/10.1007/s10207-024-00877-1
35. Wang, X., Guo, Y., Sun, Z., Yu, M., Li, F., Fang, L.: OPMonitor: continuously monitoring residual over-granted permissions in verified access control policies. Comput. Secur. (2025). https://doi.org/10.1016/j.cose.2025.104623
36. Yao, S., Shinn, N., Razavi, P., Narasimhan, K.: τ-bench: a benchmark for tool-agent-user interaction in real-world domains. ICLR. https://arxiv.org/abs/2406.12045(2025)
37. Lu, J., Holleis, T., Zhang, Y., Aumayer, B., Nan, F., Bai, H., Ma, S., Ma, S., Li, M., Yin, G., Wang, Z., Pang, R.: ToolSandbox: a stateful, conversational, interactive evaluation benchmark for LLM tool use capabilities. Findings of NAACL. (2025). https://doi.org/10.18653/v1/2025.findings-naacl.65
38. Mellafe Zuvic, D.: Capability gates are not authorization: confused-deputy failures in LLM agent frameworks. arXiv:2606.28679. https://arxiv.org/abs/2606.28679 (2026)
39. Wen, S.-F., Sharma, A.: Structuring trust: a quantitative and traceable framework for hardware security assurance. Int. J. Inf. Secur. (2026). https://doi.org/10.1007/s10207-026-01284-4
40. Wen, S.-F., Shukla, A., Katt, B.: Artificial intelligence for system security assurance: a systematic literature review. Int. J. Inf. Secur. (2025). https://doi.org/10.1007/s10207-024-00959-0
41. Shukla, A., Katt, B., Nweke, L.O., Yeng, P.K., Weldehawaryat, G.K.: System security assurance: a systematic literature review. Comput. Sci. Rev. (2022). https://doi.org/10.1016/j.cosrev.2022.100496
42. Mohamad, M., Steghöfer, J.-P., Scandariato, R.: Security assurance cases—state of the art of an emerging approach. Empir. Softw. Eng. (2021). https://doi.org/10.1007/s10664-021-09971-7
43. Ali, M., Ullah, A., Islam, M.R., Hossain, R.: Assessing of software security reliability: dimensional security assurance techniques. Comput. Secur. (2025). https://doi.org/10.1016/j.cose.2024.104230

44. Raza, S., Sapkota, R., Karkee, M., Emmanouilidis, C.: TRiSM for agentic AI: a review of trust, risk, and security management in LLM-based agentic multi-agent systems. AI Open (2026). https://doi.org/10.1016/j.aiopen.2026.02.006
45. Valenta, T., Rozinek, O., Horálek, J.: Agentic AI safety: a structured review of open problems and their regulatory anchoring. AI (2026). https://doi.org/10.3390/ai7080298
46. Kincl, J., Adam, M.T.P., Pavleska, T.: Human-AI integration in cybersecurity: an industry-aligned perspective on incident management. Int. J. Inf. Secur. (2026). https://doi.org/10.1007/s10207-026-01259-5
47. Kröger, N., Zeidler, O., Kellerer, W.: 5G open radio access network security - vulnerabilities on O-RAN interfaces and components. Int. J. Inf. Secur. (2026). https://doi.org/10.1007/s10207-026-01255-9
48. Bertolissi, C., Anton, A.M., Zannone, N.: Fine-grained access control for multi-user data in cooperative systems: managing compound objects and temporal constraints. Int. J. Inf. Secur. (2026). https://doi.org/10.1007/s10207-026-01227-z
49. Alkhorem, A.H., Conte de Leon, D., Jillepalli, A.A., Song, J.: Graph-based formal modeling and implementation of access control policies with automated conflict and redundancy detection. Int. J. Inf. Secur. (2026). https://doi.org/10.1007/s10207-025-01130-z
50. Ma, Y.-W., Chiu, P.-H.: A novel risk-based access control engine in zero trust architecture for IoT network. Int. J. Inf. Secur. (2025). https://doi.org/10.1007/s10207-025-01030-2
51. Wang, W., Zhong, N., Xiao, J., Wei, J., Chen, X.: Efficient revocable attribute-based encryption with black-box traceability. Int. J. Inf. Secur. (2026). https://doi.org/10.1007/s10207-026-01247-9
52. Madkaikar, M., Yelisetty, A., Sural, S., Vaidya, J., Atluri, V.: Performance analysis of dynamic ABAC systems using a queuing theoretic framework. Comput. Secur. (2025). https://doi.org/10.1016/j.cose.2025.104432
53. Shang, S., Wang, X., Liu, A.: ABAC policy mining method based on hierarchical clustering and relationship extraction. Comput. Secur. (2024). https://doi.org/10.1016/j.cose.2024.103717
54. Guo, Y., Wang, X., Yu, M., Li, F., Pang, Z., Fang, L.: An on-the-fly framework for usable access control policy mining. Comput. Secur. (2025). https://doi.org/10.1016/j.cose.2024.104211
55. Logrippo, L.: Data flow security in role-based access control. J. Inf. Secur. Appl. (2025). https://doi.org/10.1016/j.jisa.2025.103997
56. Zhu, X., Zou, S., Xu, G., Xi, J.: Group-capability-based access control with ring signature. J. Inf. Secur. Appl. (2025). https://doi.org/10.1016/j.jisa.2025.104014
57. Said, S., Hajlaoui, J.E., Omri, M.N.: New privacy-respecting access control-based approach for data placement in an IoT environment. J. Inf. Secur. Appl. (2025). https://doi.org/10.1016/j.jisa.2025.104192
58. Baseri, Y., Hafid, A., Firoozjaei, M.D., Cherkaoui, S., Ray, I.: Statistical privacy protection for secure data access control in cloud. J. Inf. Secur. Appl. (2024). https://doi.org/10.1016/j.jisa.2024.103823
59. Fu, C., Shen, G., Huang, Z., Xie, J., Fu, J.: Automatic IoT permission assignment with transformer models under spatiotemporal constraints. J. Inf. Secur. Appl. (2025). https://doi.org/10.1016/j.jisa.2025.104099
60. Xu, X., Yang, Z., Cai, Q., Lin, J., Ren, L., Chen, B., Huang, Y.: Enforcing cryptographic distributed-VCS access control with no trust on servers. J. Inf. Secur. Appl. (2025). https://doi.org/10.1016/j.jisa.2025.104103
61. Zhai, Y., Yang, H., Yao, J., Wang, T., Zhou, Y., Zhu, F., Yang, B.: DRAC: a dynamic fine-grained access control scheme for cloud storage with censorship-coerced resistance. J. Inf. Secur. Appl. (2025). https://doi.org/10.1016/j.jisa.2025.104123
62. Evtimov, I., Zharmagambetov, A., Grattafiori, A., Guo, C., Chaudhuri, K.: WASP: benchmarking web agent security against prompt injection attacks. NeurIPS. (2025). https://mlanthology.org/neurips/2025/evtimov2025neurips-wasp/
63. Abdelnabi, S., Fay, A., Salem, A., Zverev, E., Liao, K.-C., Liu, C.-H., Kuo, C.-C., Weigend, J., Manlangit, D., Apostolov, A., Umair, H., Donato, J., Kawakita, M., Mahboob, A., Bach, T. H., Chiang, T.-H., Cho, M., Choi, H., Kim, B., Lee, H., Pannell, B., McCauley, C., Russinovich, M., Paverd, A., Cherubin, G.: LLMail-Inject: a dataset from a realistic adaptive prompt injection challenge. arXiv:2506.09956. https://arxiv.org/abs/2506.09956 (2025)
64. An, H., Zhang, J., Du, T., Zhou, C., Li, Q., Lin, T., Ji, S.: IPIGuard: a novel tool dependency graph-based defense against indirect prompt injection in LLM agents. EMNLP. (2025). https://doi.org/10.18653/v1/2025.emnlp-main.53
65. Doshi, A., Hong, Y., Xu, C., Kang, E., Kapravelos, A., Kästner, C.: Towards verifiably safe tool use for LLM agents. ICSE NIER. (2026). https://doi.org/10.1145/3786582.3786839
66. Ling, Y., Yu, S., Chen, Z., Fang, C.: Toward secure LLM agents: threat surfaces, attacks, defenses, and evaluation. arXiv:2606.10749. https://arxiv.org/abs/2606.10749 (2026)
67. Ruan, Y., Dong, H., Wang, A., Pitis, S., Zhou, Y., Ba, J., Dubois, Y., Maddison, C. J., Hashimoto, T.: Identifying the risks of LM agents with an LM-emulated sandbox. ICLR. https://arxiv.org/abs/2309.15817 (2024)
68. Zhang, H., Huang, J., Mei, K., Yao, Y., Wang, Z., Zhan, C., Wang, H., Zhang, Y.: Agent security bench (ASB): formalizing and benchmarking attacks and defenses in LLM-based agents. ICLR. https://arxiv.org/abs/2410.02644 (2025)
69. Andriushchenko, M., Souly, A., Dziemian, M., Duenas, D., Lin, M., Wang, J., Hendrycks, D., Zou, A., Kolter, J. Z., Fredrikson, M., Gal, Y., Davies, X.: AgentHarm: a benchmark for measuring harmfulness of LLM agents. ICLR. https://arxiv.org/abs/2410.09024 (2025)
70. Janovsky, A., Jancar, J., Svenda, P., Chmielewski, Ł, Michalik, J., Matyas, V.: Sec-certs: examining the security certification practice for better vulnerability mitigation. Comput. Secur. (2024). https://doi.org/10.1016/j.cose.2024.103895
71. Dzhaliuk, N., Sabodashko, D., Khoma, V., Khoma, Y., Kolchenko, V., Podpora, M.: Comparative evaluation of machine learning methods for protecting LLMs from prompt injection attacks. Int. J. Inf. Secur. (2026). https://doi.org/10.1007/s10207-026-01264-8
72. Li, Z., Xu, J., He, H., Li, H., Wang, Q., Zhou, F.: PPLLA: privacy-preserving attribute-based LLM authorization. Inf. Sci. (2026). https://doi.org/10.1016/j.ins.2026.123623
73. Bagdasarian, E., Yi, R., Ghalebikesabi, S., Kairouz, P., Gruteser, M., Oh, S., Balle, B. and Ramage, D.: Airgapagent: protecting privacy-conscious conversational agents. In Proceedings of the 2024 on ACM SIGSAC Conference on Computer and Communications Security, pp. 3868-3882 (2024). https://doi.org/10.1145/3658644.3690350
74. Lawal, S., Zhao, X., Rios, A., Krishnan, R., Ferraiolo, D.: Translating natural language specifications into access control policies by leveraging large language models. IEEE TPS-ISA 2024 (published 2025 record). (2025). https://doi.org/10.1109/TPS-ISA62245.2024.00048
75. Hardy, N.: The confused deputy (or why capabilities might have been invented). ACM SIGOPS Oper. Syst. Rev. (1988). https://doi.org/10.1145/54289.871709

Publisher's Note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.